

Class 17 IDS, Proxy, Router & Switch For SOC L1

Router

A **router** is a networking device that **connects different networks** and forwards data packets between them.

Example:

```
Your Device → LAN → Router → Internet
```

The router decides **where each IP packet should go** so it reaches the correct destination.

What Does a Router Do?

1. Routes Packets Based on IP Address

- Reads the **destination IP address** in the packet.
- Chooses the best path using its **routing table**.
- Forwards the packet to the next router or destination.

2. Performs NAT (Network Address Translation)

- Converts **private IP addresses** (e.g., 192.168.1.10) into a **public IP address** before sending traffic to the internet.
- Allows multiple devices in a LAN to share a single public IP.

Example:

```
192.168.1.10
192.168.1.20
192.168.1.30
    |
    ▼
Router (NAT)
    |
Public IP: 103.25.x.x
```

3. Maintains a Routing Table

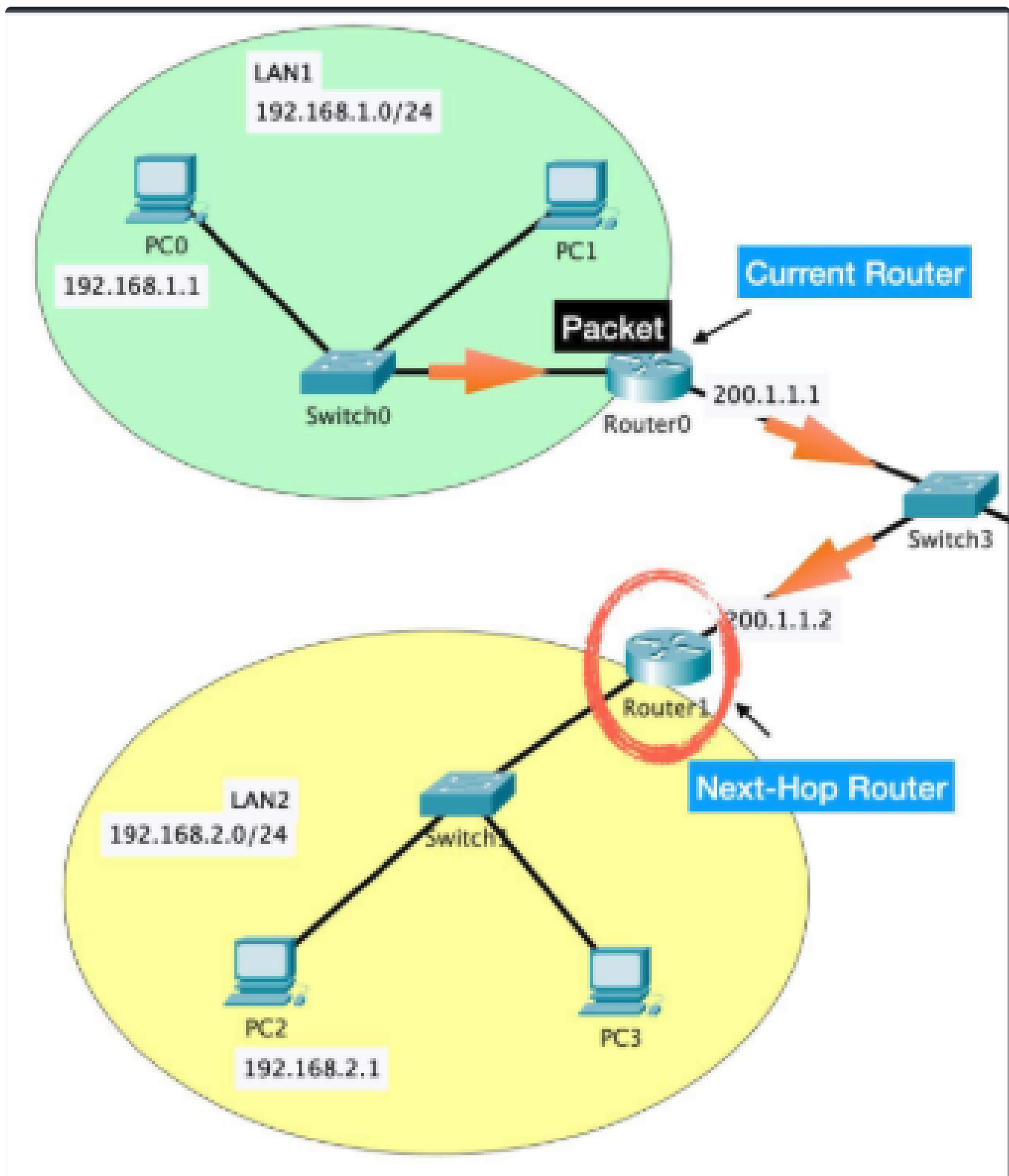
- Stores information about available networks and the best routes.
 - Uses this table to decide where to forward packets.
-

SOC Analyst Perspective

A SOC analyst may examine router logs to:

- Monitor inbound and outbound traffic.
- Detect unauthorized connections.
- Investigate suspicious IP addresses.
- Identify routing issues or unusual traffic patterns.

A **router** is a network device that connects different networks, such as a LAN and the Internet. It forwards packets based on the destination IP address using a routing table, performs **Network Address Translation (NAT)** to convert private IP addresses into a public IP, and ensures data reaches the correct destination efficiently.



Router Logs in SOC

Routers generate logs that help SOC analysts monitor and investigate network traffic.

Information Found in Router Logs

- **Source IP** – The IP address of the device sending the traffic.
 - **Destination IP** – The IP address of the device receiving the traffic.
 - **Traffic Flow** – Shows the direction and details of network communication (who is communicating with whom, using which protocol and port).
-

SOC Indicators to Look For

1. Traffic to Malicious IPs

- Internal devices communicating with **known malicious or blacklisted IP addresses**.
- May indicate malware, command-and-control (C2) communication, or compromised systems.

2. Unusual Outbound Connections

- An internal host making connections to unexpected countries, unknown servers, or unusual ports.
- Could indicate malware or unauthorized remote access.

3. Data Exfiltration

- A large amount of sensitive data leaving the organization's network.
 - May indicate an attacker stealing confidential information.
-

Example Router Log

```
Time: 10:15:32
Source IP:      192.168.1.25
Destination IP: 203.0.113.50
Protocol:       TCP
Destination Port: 443
Bytes Sent:     2.5 GB
Action:         Allowed
```

SOC Analysis

- **Source IP:** Internal employee device.
- **Destination IP:** Verify using threat intelligence.
- **Traffic:** 2.5 GB of outbound data is unusually high.
- **Action:** Investigate whether this is a legitimate file transfer or possible **data exfiltration**.

Router logs provide visibility into network traffic by recording the **source IP, destination IP, and traffic flow**. As a SOC analyst, I review these logs to identify indicators of compromise such as **connections to malicious IP addresses, unusual outbound traffic, and potential data exfiltration**. I then correlate these findings with SIEM alerts and threat intelligence to determine whether the activity is malicious or legitimate.

Switch

A **switch** is a network device that **connects multiple devices within the same Local Area Network (LAN)** and allows them to communicate efficiently.

Example:

```
PC ↔ Switch ↔ Server
```

Unlike a hub, a switch sends data **only to the intended device**, making communication faster and more secure.

What Does a Switch Do?

1. Uses MAC Addresses

- Every network device has a unique **MAC (Media Access Control) address**.
- The switch learns and stores these MAC addresses in a **MAC address table (CAM table)**.

2. Sends Data Only to the Correct Device

- When a frame arrives, the switch checks the **destination MAC address**.
- It forwards the frame **only to the port** where the destination device is connected.
- This reduces unnecessary traffic on the network.

Example

```
PC-A (MAC: AA:AA)
  |
  |
[ Switch ]
 /    \
PC-B    Server
(MAC: BB) (MAC: CC)

PC-A → Server
Switch forwards the frame only to the Server's port.
```

Router vs Switch

Switch	Router
Connects devices within the same LAN	Connects different networks (LAN to Internet)
Uses MAC addresses	Uses IP addresses
Operates mainly at Layer 2 (Data Link)	Operates at Layer 3 (Network)

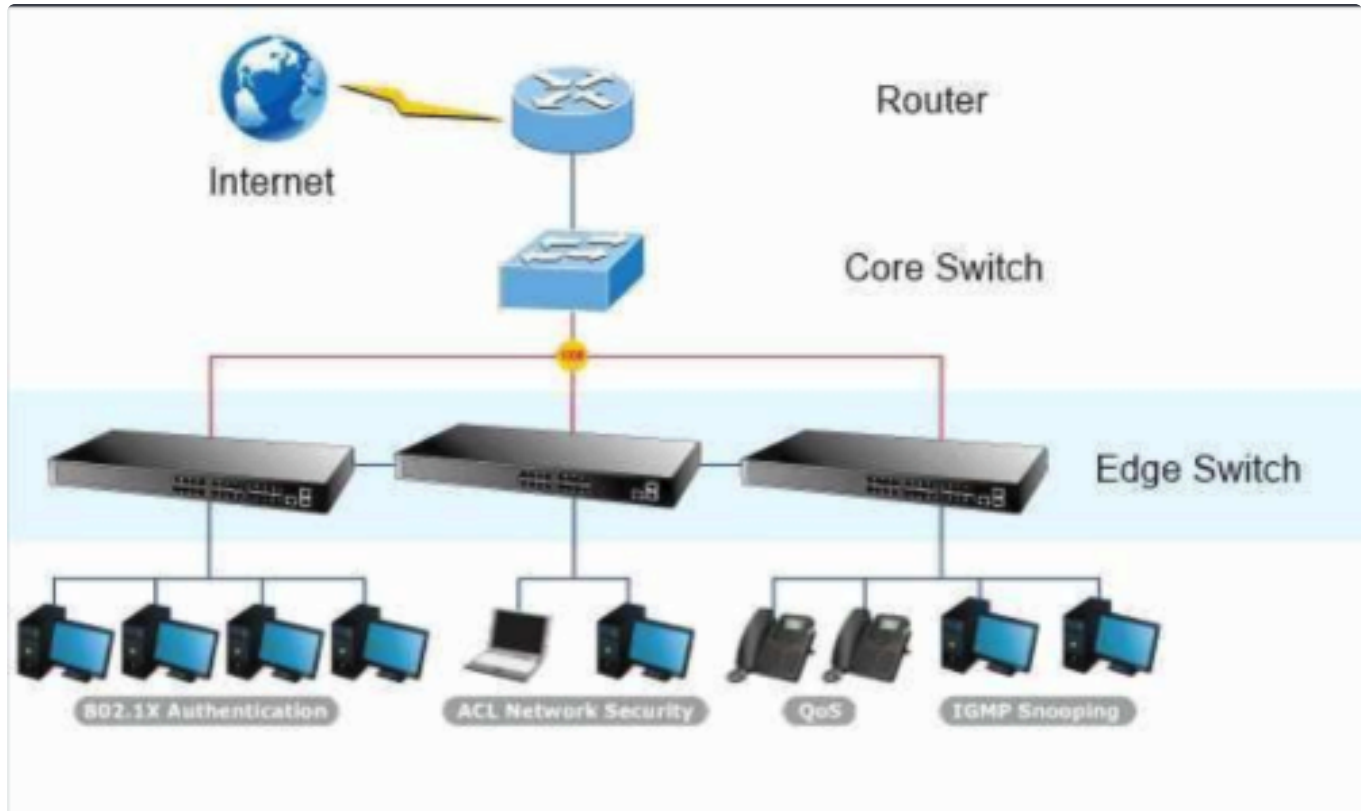
SOC Analyst Perspective

Switch logs can help identify:

- **MAC address changes** (possible device spoofing).
- **Port security violations** (unauthorized devices connected).

- **Unusual internal communication** between devices.
- **MAC flooding attacks**, where an attacker tries to overwhelm the switch's MAC table.

A **switch** is a Layer 2 network device that connects devices within the same LAN. It uses **MAC addresses** to identify connected devices and forwards Ethernet frames **only to the correct destination port**, reducing unnecessary network traffic and improving network efficiency.



Switch from a SOC Perspective

A SOC analyst uses **switch logs** to monitor communication inside the **Local Area Network (LAN)** and detect suspicious activity.

What SOC Analysts Look For

1. Detect Internal (Lateral) Movement

- Monitor communication between internal devices.
- If a compromised computer starts connecting to many other internal systems, it may indicate **lateral movement** by an attacker.

2. MAC Address Anomalies

- Check for unusual MAC address behavior, such as:
 - A MAC address appearing on multiple switch ports.
 - Frequent MAC address changes.
 - Unknown or unauthorized devices connecting to the network.
-

Common Threats

1. ARP Spoofing (ARP Poisoning)

- An attacker sends **fake ARP replies** to associate their **MAC address** with another device's IP (often the default gateway).
- Traffic meant for the gateway is redirected to the attacker.

Impact:

- Man-in-the-Middle (MITM) attacks.
 - Traffic interception.
 - Credential theft.
-

2. MAC Flooding

- An attacker sends thousands of fake MAC addresses to the switch.
- The switch's **MAC (CAM) table** becomes full.
- The switch may start **broadcasting frames** to all ports like a hub.

Impact:

- Network congestion.
 - Easier packet sniffing.
 - Potential data leakage.
-

SOC Example

Alert:

```
Switch Log:  
MAC Address: AA:BB:CC:DD:EE:FF
```

Port 3
Port 8
Port 12

Analysis

Normally, **one MAC address should appear on only one switch port.**

If the **same MAC address is seen on multiple ports**, it could indicate:

- **ARP Spoofing / ARP Poisoning**
- **Man-in-the-Middle (MITM) attack**
- MAC table instability due to loops or virtualization (should also be investigated)

The SOC analyst should:

1. Validate the switch logs.
2. Identify the affected devices and ports.
3. Check ARP tables and network traffic.
4. Correlate with firewall, endpoint, and SIEM logs.
5. Escalate if malicious activity is confirmed.

From a SOC perspective, switch logs help detect **internal network threats** such as lateral movement, MAC address anomalies, ARP spoofing, and MAC flooding. For example, if the **same MAC address appears on multiple switch ports**, it may indicate an **ARP spoofing or Man-in-the-Middle attack**. A SOC analyst validates the logs, investigates the affected hosts, correlates the event with other security logs, and escalates if malicious activity is confirmed.

VPN (Virtual Private Network)

A **VPN (Virtual Private Network)** creates a **secure, encrypted tunnel** between a user's device and a VPN server, protecting data while it travels over the internet.

Example:

User
|
Encrypted Tunnel
|

VPN Server
|
Internet / Internal Network

What Does a VPN Do?

1. Encrypts Traffic (Confidentiality)

- Encrypts data before it leaves the user's device.
- Prevents attackers, ISPs, or anyone on public Wi-Fi from reading the traffic.

2. Hides the Real IP Address (Anonymity)

- Websites and external services see the **VPN server's public IP**, not the user's real public IP.
- This improves privacy, though it does **not** make a user completely anonymous.

3. Allows Remote Access

- Employees can securely connect to the company's internal network from anywhere.
 - Commonly used for remote work and accessing internal servers.
-

SOC Analyst Perspective

SOC analysts monitor VPN logs to detect:

- **Failed login attempts** (possible brute-force attacks).
 - **Logins from unusual countries or locations.**
 - **Impossible travel** (the same user logs in from two distant locations in an unrealistically short time).
 - **Logins outside business hours.**
 - **Multiple users sharing the same VPN account.**
 - **Unusual data transfers** over the VPN, which could indicate data exfiltration.
-

Example SOC Scenario

```
User: john.doe
VPN Login: India (09:00)
VPN Login: Germany (09:20)
```

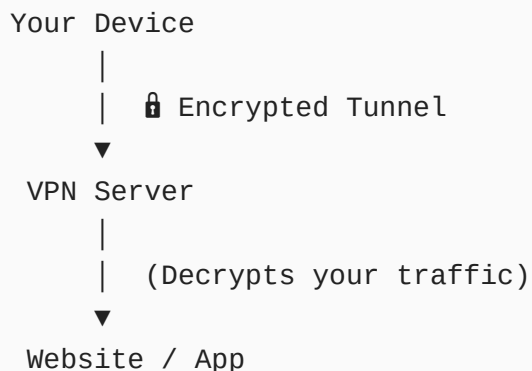
Analysis:

- It is highly unlikely the user traveled from India to Germany in **20 minutes**.
- This may indicate:
 - Stolen credentials.
 - Account compromise.
 - VPN account sharing.

The SOC analyst should validate the event, investigate the user's activity, correlate with identity and endpoint logs, and escalate if compromise is confirmed.

A **VPN (Virtual Private Network)** creates a secure, encrypted tunnel between a user's device and a VPN server. It **encrypts network traffic** to protect confidentiality, **masks the user's public IP address** by using the VPN server's IP, and enables **secure remote access** to corporate networks. From a SOC perspective, VPN logs are monitored for suspicious logins, impossible travel, brute-force attempts, and abnormal VPN activity.

How VPN Tunneling Works



1. Device → VPN Server (Encrypted ✅)

- Your laptop or phone encrypts all network traffic.

- The data travels through a **secure VPN tunnel**.
- Even if someone intercepts the traffic (e.g., on public Wi-Fi), they **cannot read it** because it is encrypted.

2. VPN Server → Website (Usually Unencrypted or Re-encrypted)

- The VPN server decrypts the traffic.
- It then forwards the request to the destination website.
- If the website uses **HTTPS**, this connection is **encrypted again using TLS**.
- If the website uses only **HTTP**, this part is **not encrypted**, which is why the diagram shows it as unencrypted.

3. Website → VPN Server → Device

- The website sends the response back to the VPN server.
- The VPN server encrypts the response again.
- The encrypted data travels through the VPN tunnel back to your device.

What the Website Sees

Without VPN:

Your Device (Real IP) —→ Website

The website sees **your real public IP address**.

With VPN:

Your Device → VPN Server → Website

The website sees **the VPN server's IP address**, not your real public IP.

SOC Analyst Perspective

As a SOC analyst, VPN logs can reveal:

- User login/logout time.
- User identity.
- Source public IP.
- Assigned VPN IP.
- Data uploaded/downloaded.
- Failed login attempts.
- Login location.
- Session duration.

Example SOC Alert

```
User: alice
VPN Login: 02:15 AM
Source IP: Russia
Company: India
Status: Success
```

Analysis:

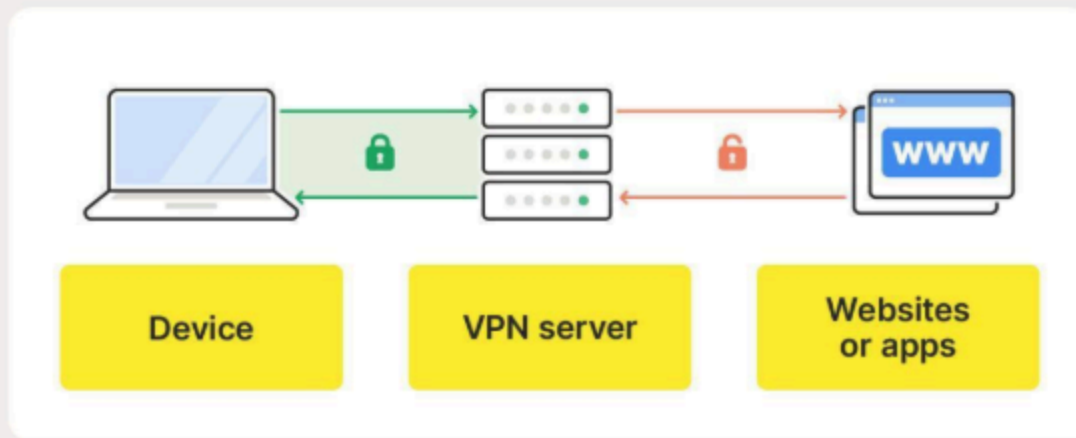
- Login occurred from an unusual country.
- Outside normal working hours.
- Requires validation with the user and correlation with other security logs.
- Could indicate **stolen VPN credentials** or an **account compromise**.

Interview Answer (30 Seconds)

VPN tunneling creates an **encrypted tunnel** between a user's device and a VPN server. The user's traffic is encrypted before leaving the device, protecting it from interception. The VPN server decrypts the traffic and forwards it to the destination website, which sees the VPN server's IP instead of the user's real IP. For websites using HTTPS, the connection remains encrypted end-to-end. From a SOC perspective, VPN logs are monitored for suspicious logins, failed authentication attempts, unusual locations, and potential account compromise.

How VPN tunneling works

→  Encrypted →  Unencrypted



Types of VPN

1. Remote Access VPN

A **Remote Access VPN** allows an individual user (such as an employee) to securely connect to the company's internal network from any location.

Example:

- Work from home.
- Accessing office resources while traveling.

```
Employee
|
Encrypted VPN Tunnel
|
Company VPN Server
|
Internal Network
```

2. Site-to-Site VPN

A **Site-to-Site VPN** securely connects **two or more office networks** over the Internet.

Example:

Office A — Encrypted VPN Tunnel — Office B

Employees in both offices can communicate securely as if they were on the same network.

3. SSL VPN

An **SSL VPN** uses **SSL/TLS encryption over HTTPS (Port 443)** to provide secure remote access.

Features:

- Uses **HTTPS (TCP Port 443)**.
 - Common in corporate environments.
 - Users often connect through a web browser or VPN client.
-

SOC Perspective

Normal VPN Behavior

```
User Device
  |
Real Public IP
  |
VPN Tunnel
  ▼
VPN Server (VPN IP)
  |
Internal Company Systems
```

A SOC analyst expects to see:

- User logs in from a legitimate public IP.
- VPN assigns an internal/VPN IP.

- User accesses only authorized internal resources.
 - Normal login time and session duration.
-

Suspicious VPN Indicators

A SOC analyst investigates:

- Multiple failed VPN login attempts (possible brute-force attack).
 - Login from an unusual country or location.
 - Impossible travel (same user logs in from distant locations in a short time).
 - VPN login outside normal working hours.
 - Excessive data transfer (possible data exfiltration).
 - Multiple simultaneous VPN sessions for the same user.
-

Example SOC Scenario

```
User: john
Source IP: 45.10.x.x (Unknown Country)
VPN Login: Success
Downloaded: 20 GB
Time: 03:10 AM
```

SOC Analysis

- **Source IP:** Unusual location.
- **Login Time:** Outside business hours.
- **Data Download:** Very large amount of data.
- **Action:** Investigate for possible account compromise or data exfiltration by correlating VPN logs with endpoint, firewall, and SIEM alerts.

There are three common types of VPNs. **Remote Access VPN** allows employees to securely connect to the corporate network from anywhere. **Site-to-Site VPN** securely connects two or more office networks over the Internet. **SSL VPN** uses HTTPS on **port 443** to provide encrypted remote access. From a SOC perspective, analysts

monitor VPN logs for normal user behavior and investigate suspicious activities such as failed logins, unusual locations, impossible travel, and large data transfers.

VPN Suspicious Indicators (SOC Perspective)

As a SOC analyst, these behaviors may indicate a compromised account or malicious activity.

1. Login from an Unusual Country

- A user who normally logs in from **India** suddenly logs in from **Germany** or another unexpected country.
- Could indicate stolen VPN credentials.

2. Multiple Logins from Different Locations

- The same user account logs in from **two different countries** within a very short time.
- This is known as **Impossible Travel**.

3. Suspicious Activity After VPN Login

- The user successfully connects to the VPN.
- Immediately after login, the account:
 - Accesses sensitive servers.
 - Runs administrative commands.
 - Downloads confidential files.
- This may indicate an attacker using a compromised account.

4. High Data Transfer Through VPN

- A user transfers an unusually large amount of data through the VPN.
- Could indicate **data exfiltration**.

Common VPN Abuse

Attackers use VPNs to:

- **Hide their real IP address.**
- **Bypass geographic restrictions (Geo-blocking).**

- **Gain remote access** to an organization's internal network using stolen credentials.
-

SOC Example

```
User: admin
Login Country: Germany
VPN Server: India
Previous Login: India
Time Difference: 2 minutes
```

SOC Analysis (Using Your Workflow)

1. Validate

- Confirm the VPN login is genuine.
- Check VPN authentication logs.
- Verify timestamps.

2. Investigate

- User: **admin**
- Previous login: **India**
- Current login: **Germany**
- Time difference: **2 minutes**
- Check endpoint logs and recent user activity.

3. Correlate

- Compare with:
 - VPN logs
 - Active Directory/Identity logs
 - Endpoint (EDR) logs
 - Firewall logs
- Determine whether the account performed any unusual actions after login.

4. Enrich

- Check the source IP's reputation.

- Verify whether the IP belongs to a VPN provider, hosting service, or known malicious infrastructure.
- Contact the user, if appropriate, to confirm their location.

5. Decide

- Traveling from **India to Germany in 2 minutes is impossible**.
- This is an **Impossible Travel** event.
- Most likely causes:
 - Compromised credentials.
 - Stolen VPN account.
 - Session hijacking.

6. Escalate

- Escalate to the Incident Response team.
- Disable or lock the account if compromise is confirmed.
- Force a password reset and revoke active VPN sessions.
- Review systems accessed during the VPN session.

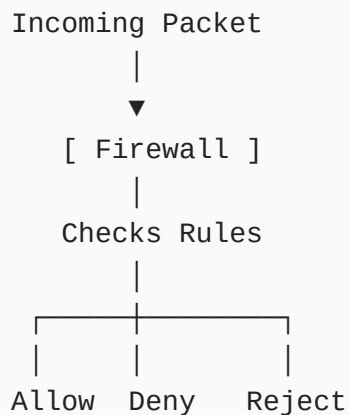
From a SOC perspective, suspicious VPN activity includes logins from unusual countries, multiple logins from different locations within a short time (impossible travel), suspicious actions immediately after VPN login, and unusually high data transfers. For example, if the **admin** account logs in from **India** and then from **Germany** just **2 minutes later**, it is an **impossible travel** event and may indicate a compromised account. The SOC analyst validates the login, investigates related logs, correlates events across security tools, and escalates the incident if malicious activity is confirmed.

Firewall

A **firewall** is a security device or software that **monitors and controls incoming and outgoing network traffic** based on predefined security rules.

Its main purpose is to **allow legitimate traffic** and **block unauthorized or malicious traffic**.

How a Firewall Works



1. Accept (Allow) ✓

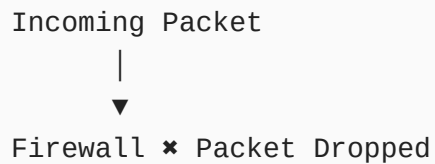
- The packet **matches an allowed rule**.
- The firewall **permits the packet** to pass.



Example: Allow HTTPS traffic on **TCP Port 443**.

2. Deny (Drop) ✗

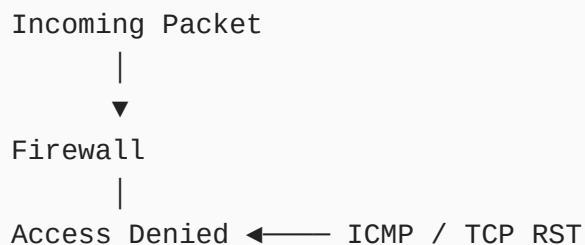
- The firewall **silently discards** the packet.
- **No response** is sent to the sender.



Example: Block traffic from a malicious IP address.

3. Reject ❌

- The firewall **blocks** the packet.
- It **sends a response** (such as an ICMP "Destination Unreachable" or TCP RST) back to the sender, informing them that access was denied.

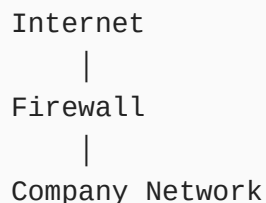


Types of Firewalls

Network Firewall

- Protects an **entire network**.
- Placed between the internal network and the Internet.
- Filters traffic based on:
 - Source IP
 - Destination IP
 - Port
 - Protocol

Example:



SOC Perspective

Firewall logs are one of the most important log sources in a SIEM.

A SOC analyst looks for:

- Repeated blocked connection attempts.
- Traffic from or to **malicious IP addresses**.
- Port scanning.
- Brute-force login attempts.
- Unauthorized access attempts.
- Unusual outbound connections.

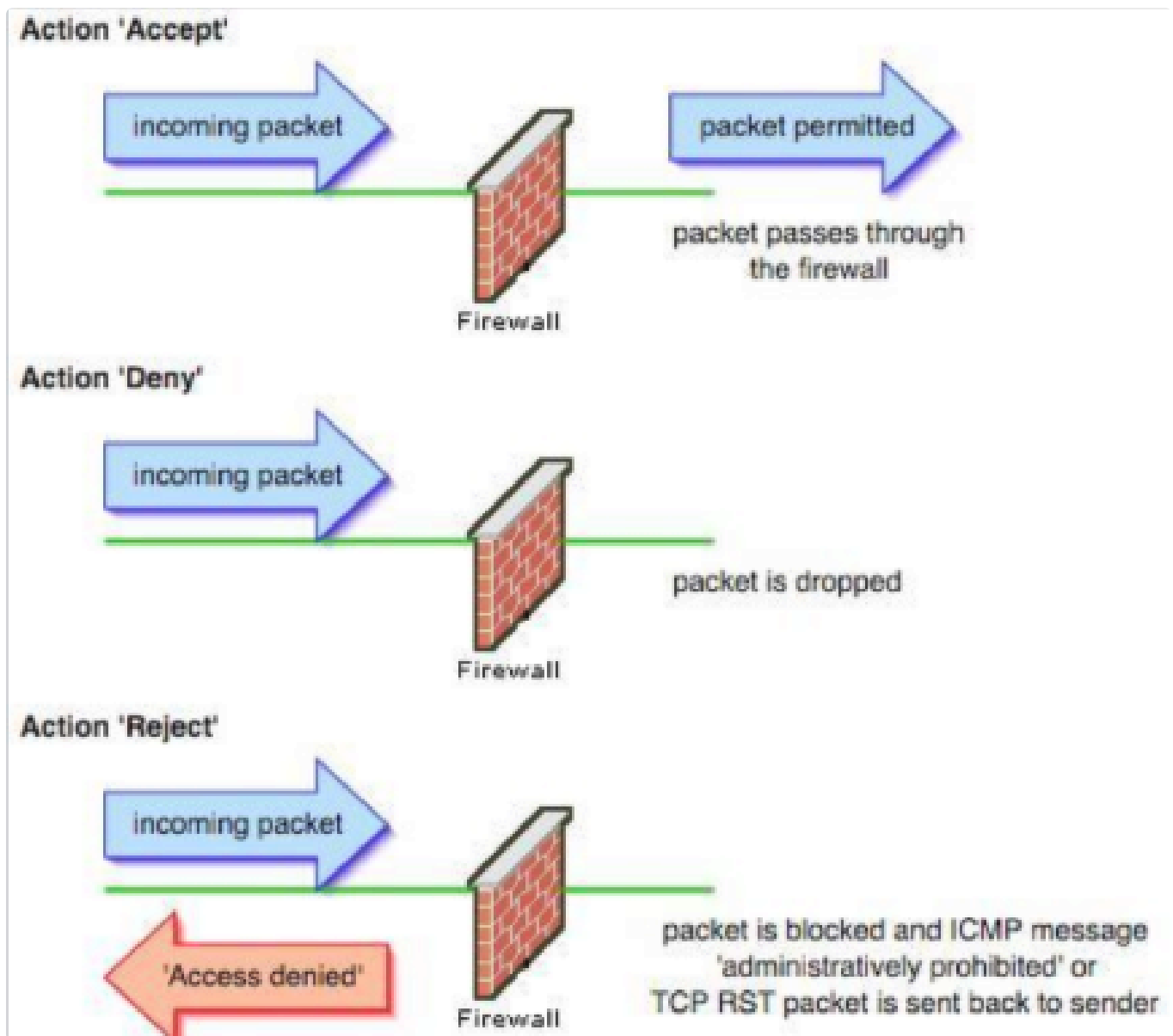
SOC Example

```
Time: 10:30:15
Action: DENY
Source IP: 185.221.x.x
Destination IP: 192.168.1.20
Destination Port: 22 (SSH)
Protocol: TCP
```

Analysis

- External IP attempted to connect to **SSH (Port 22)**.
- Firewall **denied** the connection.
- If many such attempts occur, it may indicate:
 - SSH brute-force attack.
 - Port scanning.
 - Reconnaissance activity.

A **firewall** is a network security device or software that monitors and controls network traffic based on predefined security rules. It can **allow (accept)** traffic, **deny (drop)** traffic silently, or **reject** traffic by sending an error response to the sender. From a SOC perspective, firewall logs are analyzed to detect malicious IPs, port scans, brute-force attacks, unauthorized access attempts, and other suspicious network activity.



Firewall & DMZ (SOC Perspective)

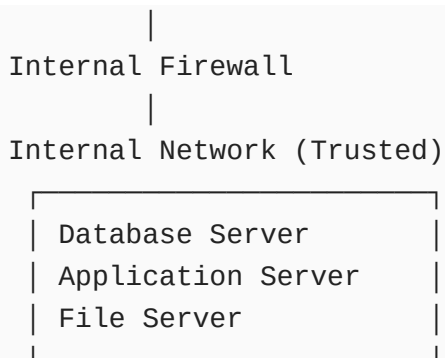
The image shows a **DMZ (Demilitarized Zone)**, which is a separate network placed between the **Internet** and the **Internal Network** to protect critical systems.

Internet (Untrusted)

External Firewall

DMZ

Web Server
Mail Server
DNS Server



Why Use a DMZ?

- Public-facing servers (Web, Mail, DNS) are placed in the **DMZ**.
- Sensitive systems (Database, File, Application servers) remain in the **Internal Network**.
- Even if a web server is compromised, the attacker **cannot directly access** the internal network because the **internal firewall** blocks unauthorized traffic.

SOC Indicators from Firewall Logs

1. Blocked Attack Attempts

- Firewall denies malicious connections.
- Example:
 - SSH brute force.
 - RDP brute force.
 - Exploit attempts.

2. Port Scanning

- One source IP attempts connections to many different ports.

Example:

Source IP: 185.221.x.x

Port 21

Port 22

```
Port 23
Port 25
Port 80
Port 443
Port 3389
```

This may indicate **reconnaissance** before an attack.

3. Suspicious Outbound Traffic

- An internal host connects to:
 - Known malicious IPs.
 - Command-and-Control (C2) servers.
 - Unusual countries.
 - Could indicate malware or data exfiltration.
-

SOC Example

```
Destination Port: 3389 (RDP)
Attempts: 500
Action: Denied
Source IP: 185.221.x.x
```

SOC Analysis (Using Your Workflow)

1. Validate

- Confirm the firewall logs.
- Verify that **500 connection attempts** occurred.
- Ensure the action is **Denied**.

2. Investigate

- Destination port: **3389 (Remote Desktop Protocol)**.
- Source IP: External.
- High number of failed connection attempts.

3. Correlate

- Check:
 - IDS/IPS alerts.
 - Windows Event Logs.
 - Authentication logs.
 - SIEM alerts.
- Determine whether any login attempts succeeded.

4. Enrich

- Check the source IP's reputation using threat intelligence.
- Look for previous malicious activity from the same IP.

5. Decide

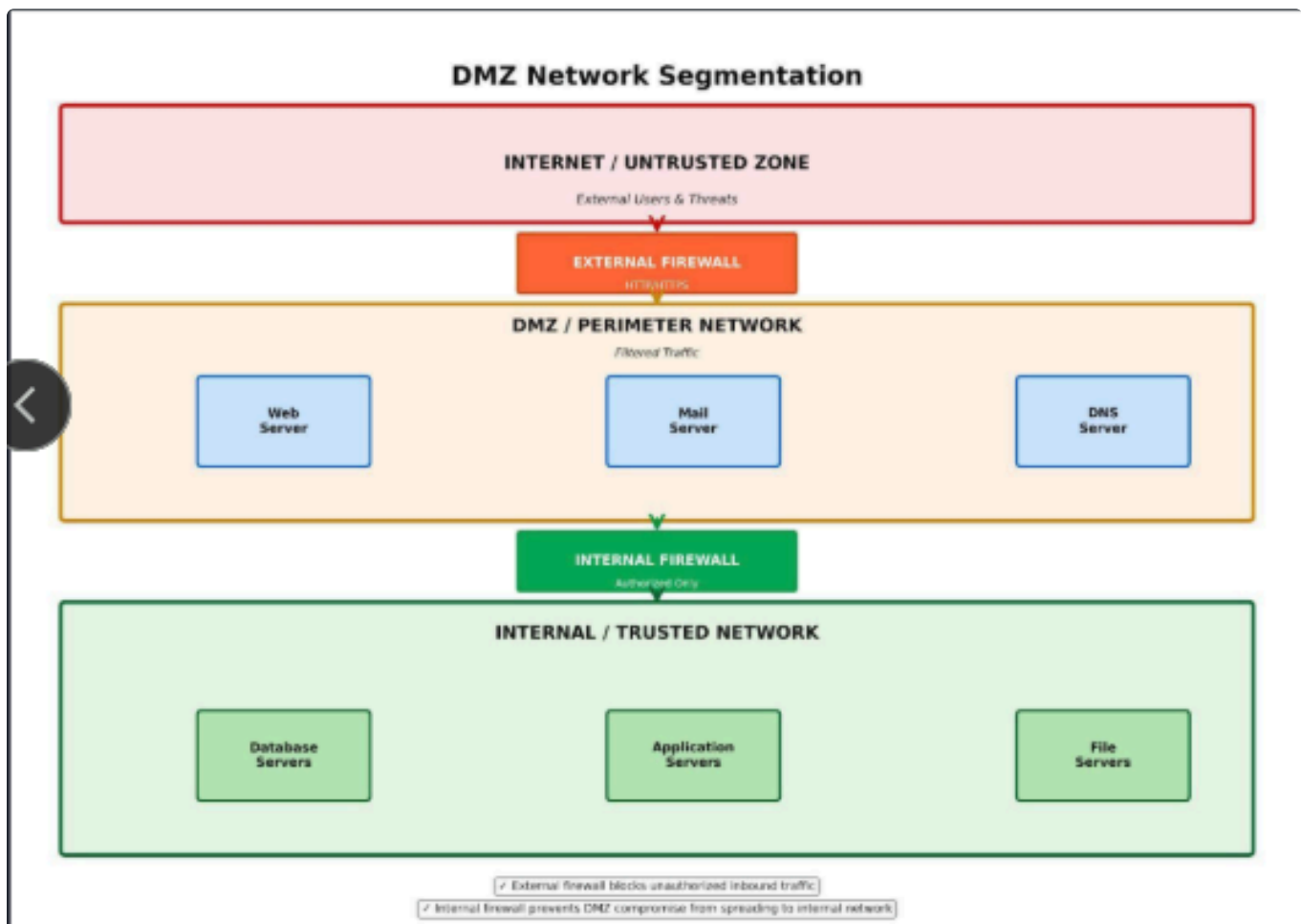
- **500 denied attempts** to RDP are **not normal behavior**.
- This strongly indicates an **RDP brute-force attack**.

6. Escalate

- Block the attacking IP (if not already blocked).
- Enable account lockout and MFA for RDP.
- Notify the Incident Response or Network team.
- Monitor for additional attacks from other IPs.

Interview Answer (30 Seconds)

A **DMZ (Demilitarized Zone)** is a network segment placed between the Internet and the internal network to host public-facing servers such as web, mail, and DNS servers. External and internal firewalls isolate the DMZ from both the Internet and the trusted internal network, reducing the risk of attackers reaching critical systems. From a SOC perspective, firewall logs are monitored for **blocked attack attempts**, **port scanning**, and **suspicious outbound traffic**. For example, **500 denied connection attempts to port 3389 (RDP)** from an external IP strongly indicate an **RDP brute-force attack**.



IDS/IPS

IDS (Intrusion Detection System) and **IPS (Intrusion Prevention System)** are network security tools that detect and help stop cyber attacks.

- **IDS** monitors network traffic and **alerts** on suspicious activity.
- **IPS** monitors traffic **and automatically blocks** malicious traffic in real time.

They are commonly integrated into **Next-Generation Firewalls (NGFWs)** and **Unified Threat Management (UTM)** devices.

IDS (Intrusion Detection System)

What it Does

- Monitors network traffic.
- Detects suspicious or malicious activity.
- Generates alerts for the SOC team.

- **Does not block** the traffic.

Flow



Think of IDS as a CCTV camera.

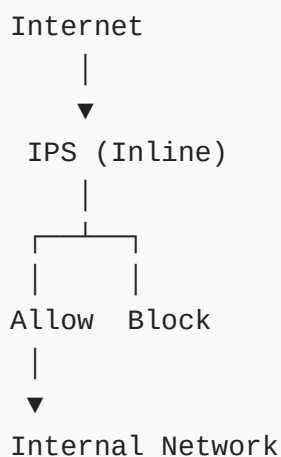
- It **watches** and **reports** suspicious activity.
- It **cannot stop** the attacker.

IPS (Intrusion Prevention System)

What it Does

- Monitors network traffic.
- Detects attacks.
- **Automatically blocks or drops** malicious packets.

Flow



Think of **IPS** as a security guard.

- It **detects** an attacker.
- It **stops** the attacker immediately.

IDS vs IPS

Feature	IDS	IPS
Full Form	Intrusion Detection System	Intrusion Prevention System
Detects attacks	✓	✓
Alerts SOC	✓	✓
Blocks attacks	✗	✓
Position	Passive (out-of-band)	Inline (in the traffic path)

SOC Perspective

A SOC analyst monitors IDS/IPS alerts for:

- Malware communication.
- Port scanning.
- SQL Injection attacks.
- Cross-Site Scripting (XSS).
- Brute-force login attempts.
- Exploit attempts.
- Command-and-Control (C2) traffic.

Example

Alert:
Source IP: 185.221.x.x

Destination: Web Server
Attack: SQL Injection

IDS Response

- Detects the SQL Injection attempt.
- Generates an alert.
- Traffic still reaches the web server unless another control blocks it.

IPS Response

- Detects the SQL Injection attempt.
 - Drops the malicious packet.
 - Prevents the attack from reaching the web server.
 - Generates an alert.
-

SOC Workflow

Validate

- Confirm the IDS/IPS alert is genuine.
- Check the attack signature and timestamp.

Investigate

- Identify:
 - Source IP
 - Destination
 - Attack type
 - Targeted service

Correlate

- Compare with:
 - Firewall logs
 - Web server logs
 - SIEM alerts
 - Endpoint logs

Enrich

- Check IP reputation.
- Determine whether the attack signature is known.

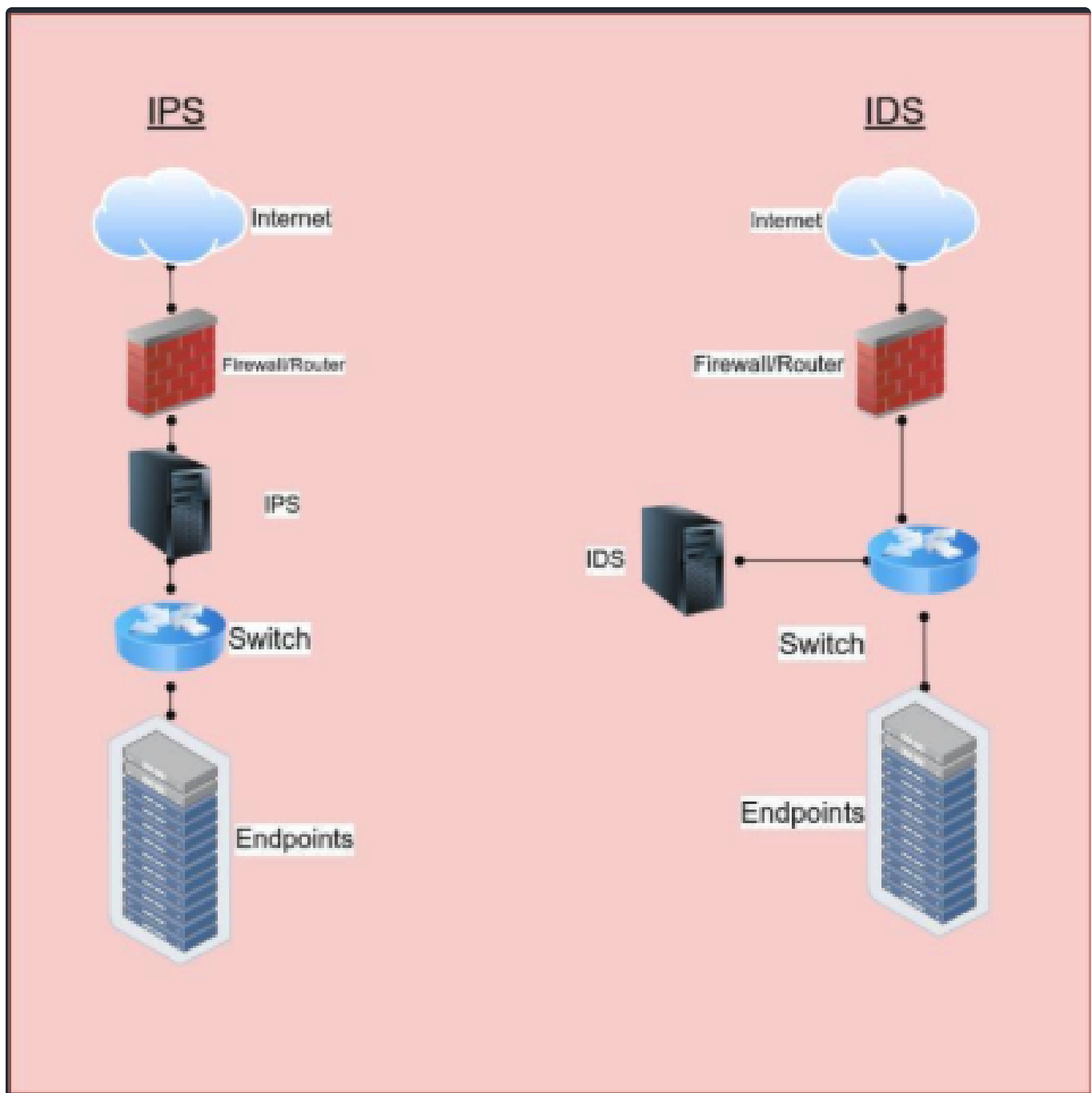
Decide

- If IDS → Investigate whether the attack succeeded.
- If IPS → Confirm the malicious traffic was blocked and assess whether any additional action is needed.

Escalate

- Escalate if the attack is successful, repeated, or part of a larger campaign.

IDS (Intrusion Detection System) monitors network traffic, detects suspicious activity, and generates alerts for the SOC team, but it does **not** block attacks. **IPS (Intrusion Prevention System)** performs the same detection but is deployed **inline**, allowing it to automatically **block or drop malicious traffic** in real time. In a SOC, IDS/IPS alerts are analyzed alongside firewall, endpoint, and SIEM logs to detect and respond to cyber threats.



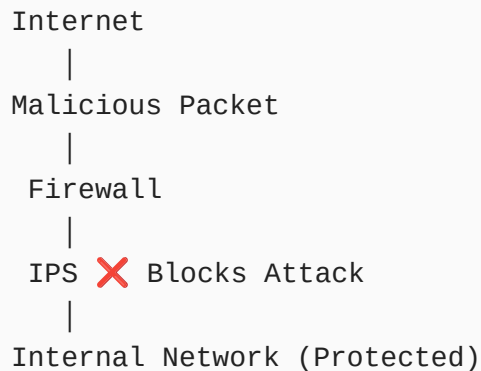
IPS (Left Side)

```
Internet
|
Firewall/Router
|
IPS ← Inline (in the traffic path)
|
Switch
|
Endpoints
```

How IPS Works

- Every packet **must pass through the IPS**.
- The IPS inspects the traffic **before it reaches the internal network**.
- If the traffic is malicious, the IPS **blocks or drops it immediately**.

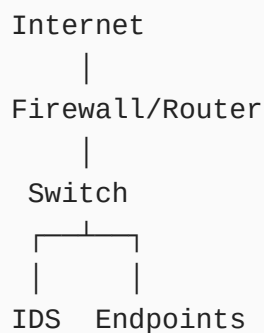
Example:



Key Point:

- **Inline deployment**
- Can **detect + prevent** attacks.
- If the IPS fails, it may interrupt traffic unless configured with fail-open/fail-close behavior.

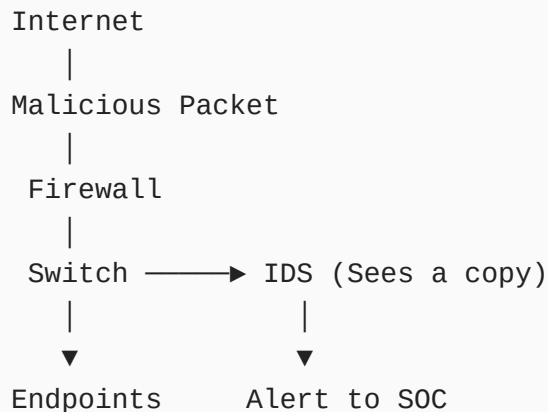
IDS (Right Side)



How IDS Works

- The IDS is connected to the **switch** (using a SPAN/mirror port or network TAP).
- It receives a **copy** of the network traffic.
- Since packets do **not** pass through the IDS, it **cannot block** attacks.
- It only detects suspicious activity and sends alerts.

Example:



Key Point:

- **Out-of-band deployment**
- Detects and alerts only.
- Does not affect normal network traffic.

IDS vs IPS Placement

Feature	IDS	IPS
Position	Connected to a mirror/SPAN port (out-of-band)	Inline between firewall and internal network
Sees traffic	Copy of traffic	All traffic
Blocks attacks	✗ No	✓ Yes
Generates alerts	✓ Yes	✓ Yes
Affects traffic flow	✗ No	✓ Yes

SOC Perspective

IDS Alert Example

```
Alert:
Attack: SQL Injection
Action: Alert Only
Status: Traffic Allowed
```

SOC Action:

- Investigate the alert.
- Check firewall, web server, and SIEM logs.
- Determine whether the attack succeeded.

IPS Alert Example

```
Alert:
Attack: SQL Injection
Action: Blocked
Status: Prevented
```

SOC Action:

- Verify the IPS successfully blocked the attack.
- Check if similar attacks are occurring from other IP addresses.
- Monitor for repeated attempts and escalate if necessary.

Easy Way to Remember

- **IDS = Detect + Alert** 👁️👁️
 - Like a **CCTV camera**: it watches and notifies but cannot stop an intruder.
- **IPS = Detect + Block** 🛡️
 - Like a **security guard**: it watches and physically stops the intruder.

The main difference between IDS and IPS is **where they are deployed** and **what they do**. An **IDS** is deployed **out-of-band**, usually connected to a switch's SPAN or mirror port, where it analyzes a copy of network traffic and generates alerts but cannot block attacks. An **IPS** is deployed **inline** between the firewall and the internal network, so all traffic passes through it. It can detect malicious traffic and automatically block or drop it before it reaches the destination. From a SOC perspective, IDS provides visibility through alerts, while IPS actively prevents attacks in real time.

SOC Perspective

An IDS or IPS can generate alerts when it detects suspicious or malicious network activity.

1. SQL Injection (SQLi)

What it is:

- An attacker tries to inject malicious SQL commands into a web application's database.

SOC Alert Example:

```
Alert: SQL Injection Attempt
Source IP: 185.221.x.x
Target: Web Server
Action:
IDS → Alert Only
IPS → Blocked
```

SOC Action:

- Check web server logs.
- Verify if the attack succeeded.
- Block the source IP if necessary.

2. Malware Traffic

What it is:

- An infected device communicates with a malicious server (Command & Control server).

SOC Alert Example:

```
Alert: Malware Communication
Source IP: 192.168.1.25
Destination IP: 45.77.x.x
Protocol: HTTPS
```

SOC Action:

- Isolate the infected endpoint.
 - Run EDR/antivirus scans.
 - Check for data exfiltration.
-

3. Exploit Attempts

What it is:

- An attacker attempts to exploit a known software vulnerability.

SOC Alert Example:

```
Alert: Apache Log4j Exploit Attempt
Source IP: 185.221.x.x
Target: Web Server
```

SOC Action:

- Verify if the exploit succeeded.
 - Patch the vulnerable system.
 - Block the attacker.
-

SOC Challenge

One of the biggest challenges for a SOC analyst is distinguishing **real attacks** from **false positives**.

Common Challenges

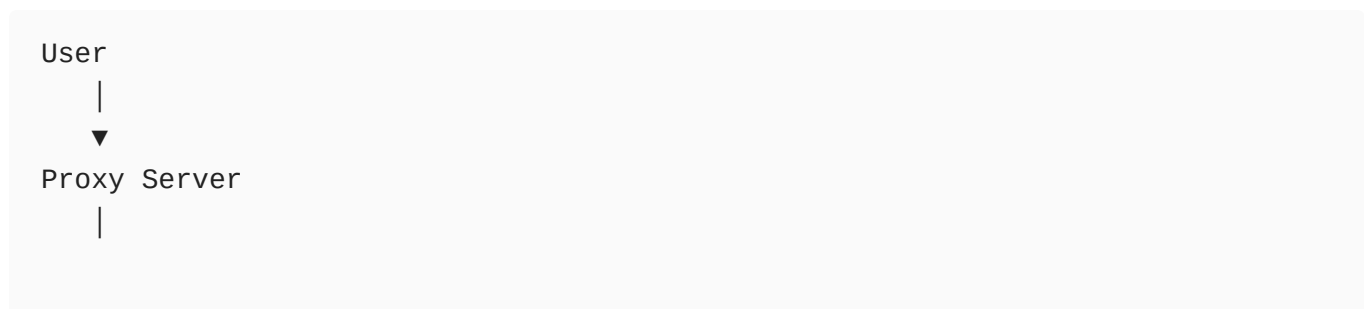
- **False Positives**
 - A legitimate activity is incorrectly flagged as malicious.
 - Example: A vulnerability scanner triggers an SQL Injection alert during an authorized security scan.
- **Alert Fatigue**
 - Thousands of alerts are generated daily.
 - Analysts must prioritize high-risk alerts.
- **False Negatives**
 - A real attack is missed because it doesn't match existing detection rules.
- **Correlation**
 - A single alert may not be enough.
 - Analysts correlate IDS/IPS alerts with firewall, SIEM, endpoint (EDR), and authentication logs to understand the full picture.

IDS and IPS commonly generate alerts for **SQL Injection**, **malware communication**, and **exploit attempts**. As a SOC analyst, I first validate the alert, investigate the source and destination, correlate it with firewall, endpoint, and SIEM logs, enrich it with threat intelligence, and determine whether it is a true positive or a false positive. One of the biggest SOC challenges is handling **false positives** while ensuring that genuine attacks are detected and responded to quickly.

Proxy Server

A **proxy server** acts as an **intermediary (middleman)** between a user's device and the Internet.

Instead of connecting directly to a website, the user sends the request to the **proxy server**, which then forwards the request to the website on behalf of the user.





What Does a Proxy Server Do?

1. Hides the User's IP Address

- Websites see the **proxy server's IP** instead of the user's real IP.
- Provides basic anonymity.

2. Filters Web Traffic

- Organizations use proxies to:
 - Block malicious websites.
 - Restrict access to social media or other sites.
 - Enforce company browsing policies.

3. Caches Content

- Frequently accessed web pages are stored (cached).
- Improves browsing speed and reduces bandwidth usage.

Proxy vs VPN

Feature	Proxy	VPN
Works at	Application Layer (e.g., browser)	Operating System / Network Level
Encrypts Traffic	❌ Usually No	✅ Yes (e.g., AES-256)
Hides IP	✅ Yes	✅ Yes
Protects All Traffic	❌ Only configured applications	✅ All device traffic
Security	Low	High
Speed	Usually Faster	Slightly Slower (due to encryption)

Feature	Proxy	VPN
Best Use	IP masking, content filtering, geo-restrictions	Privacy, secure remote access, public Wi-Fi protection

Easy Way to Remember

- **Proxy = Changes your IP.**
 - **VPN = Changes your IP + Encrypts all your traffic.**
-

SOC Perspective

SOC analysts monitor proxy logs because they provide visibility into users' web activity.

Typical information in proxy logs:

- User name
 - Source IP
 - Destination URL/Domain
 - Timestamp
 - HTTP method (GET, POST)
 - Action (Allowed/Blocked)
 - Bytes transferred
-

SOC Indicators

Watch for:

- Access to **malicious domains**.
 - Connections to **phishing websites**.
 - Downloads of suspicious files.
 - Users bypassing company web policies.
 - Excessive uploads (possible data exfiltration).
 - Connections to anonymizers or unauthorized proxy services.
-

SOC Example

```
User: john
Source IP: 192.168.1.25
URL: hxxp://malicious-site.com
Action: Allowed
```

SOC Analysis

1. Validate

- Confirm the proxy log is legitimate.
- Verify the timestamp and user.

2. Investigate

- Check whether the domain has a malicious reputation.
- Determine what the user accessed or downloaded.

3. Correlate

- Review:
 - DNS logs
 - Firewall logs
 - Endpoint (EDR) logs
 - SIEM alerts

4. Enrich

- Check threat intelligence for the domain or IP.
- Determine whether it is associated with phishing or malware.

5. Decide

- If the domain is malicious, treat it as a potential compromise.

6. Escalate

- Isolate the endpoint if malware is suspected.
- Block the domain at the proxy or firewall.
- Notify the Incident Response team.

A **proxy server** is an intermediary between a user and the Internet. It forwards requests on behalf of the user, hiding the user's IP address and allowing organizations to filter web traffic and cache frequently accessed content. Unlike a VPN, a proxy usually **does not encrypt traffic** and typically works only for specific applications, such as a web browser. From a SOC perspective, proxy logs are valuable for detecting access to malicious websites, phishing attempts, policy violations, and potential data exfiltration.

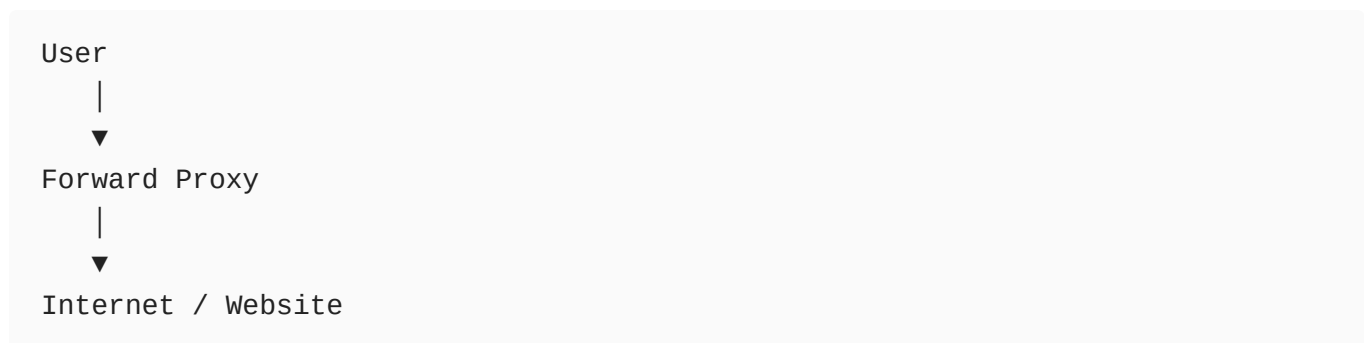
Forward Proxy & Reverse Proxy

Both are **proxy servers**, but they serve different purposes.

Forward Proxy	Reverse Proxy
Sits in front of clients (users)	Sits in front of servers
Handles outgoing requests	Handles incoming requests
Protects the client	Protects the server
Hides the client's IP	Hides the server's IP
Used for content filtering, anonymity, and web access control	Used for load balancing, caching, SSL termination, and DDoS protection

1. Forward Proxy

A **Forward Proxy** sits between the **user** and the Internet.



How it Works

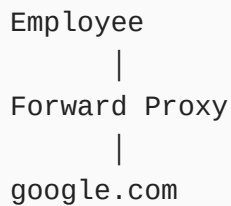
1. User sends a request.

2. The request goes to the forward proxy.
3. The proxy checks company policies.
4. If allowed, it forwards the request to the website.
5. The response comes back through the proxy.

Uses

- Hide the user's IP.
- Block restricted websites.
- Monitor employee internet usage.
- Cache frequently visited websites.

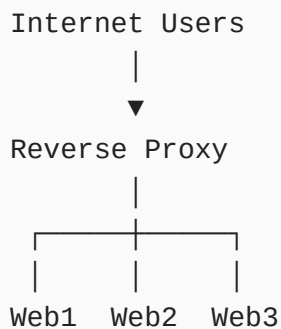
Example



The website sees the **proxy IP**, not the employee's IP.

2. Reverse Proxy

A **Reverse Proxy** sits in front of one or more **servers**.



How it Works

1. A user sends a request.
2. The request reaches the reverse proxy.
3. The reverse proxy decides which backend server should handle it.

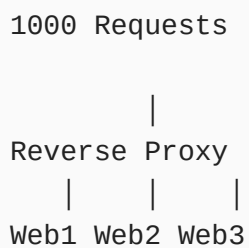
4. The selected server responds.
5. The response is returned through the reverse proxy.

The client never communicates directly with the backend server.

What Does a Reverse Proxy Do?

1. Load Balancing

Distributes requests among multiple servers.



No single server becomes overloaded.

2. Caching

Stores frequently requested content.

Instead of asking the web server every time:



This improves performance.

3. SSL/TLS Termination

The reverse proxy decrypts HTTPS traffic before forwarding requests to backend servers.

This reduces the processing load on the web servers.

4. Security

Protects backend servers by:

- Hiding their real IP addresses.
- Blocking malicious requests.
- Filtering attacks.
- Helping mitigate DDoS attacks.

Examples include **Nginx**, **HAProxy**, and **Cloudflare**.

SOC Perspective

Forward Proxy Logs

SOC analysts monitor:

- User browsing history.
 - Access to malicious websites.
 - Malware downloads.
 - Data uploads.
 - Policy violations.
-

Reverse Proxy Logs

SOC analysts monitor:

- Web attacks (SQL Injection, XSS).
 - DDoS attempts.
 - Requests from malicious IPs.
 - HTTP errors (403, 404, 500).
 - Unusual request rates.
-

SOC Example

Forward Proxy Alert

```
User: Alice
URL: malicious-site.com
Action: Allowed
```

Investigation

- Check if the website is malicious.
 - Determine whether malware was downloaded.
-

Reverse Proxy Alert

```
Source IP: 185.221.x.x
Requests: 20,000/minute
Target: Web Server
```

Investigation

- Excessive requests indicate a possible **DDoS attack**.
 - Check WAF, firewall, and server logs.
 - Block the malicious IP if appropriate.
-

Easy Way to Remember

Forward Proxy

Users → Proxy → Internet

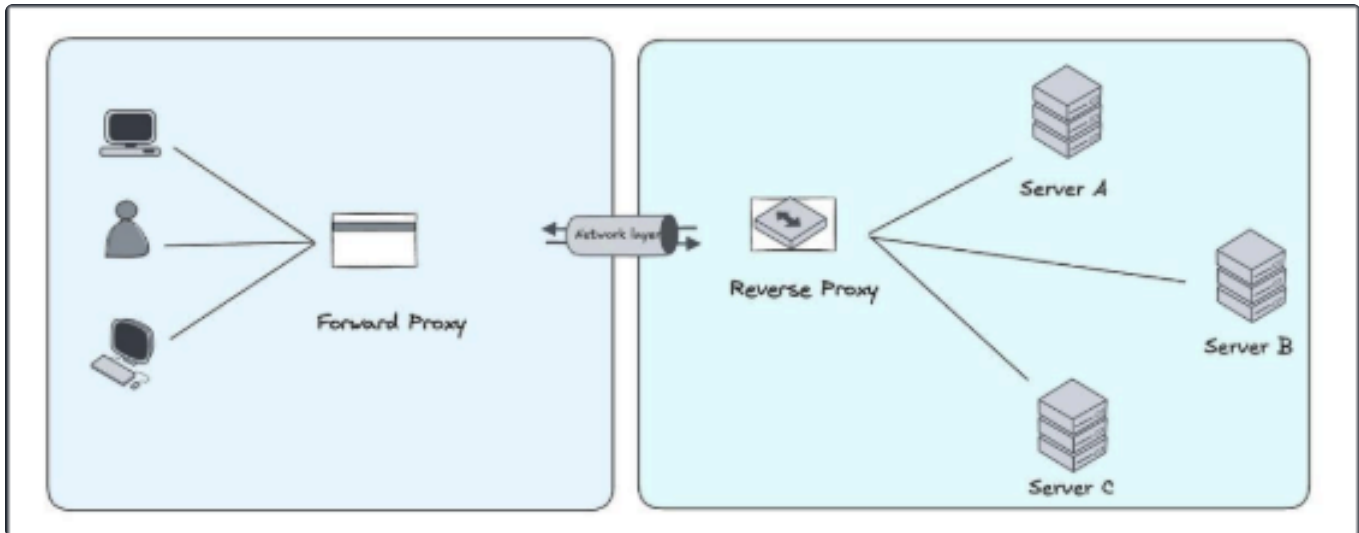
👉 Protects **Users**

Reverse Proxy

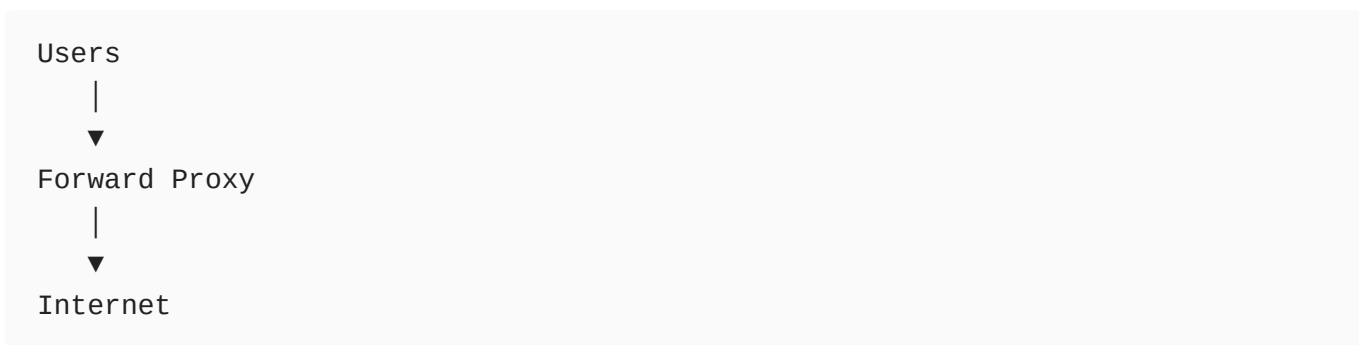
Internet → Proxy → Servers

👉 Protects **Servers**

A **Forward Proxy** sits in front of clients and handles **outbound requests**. It hides the user's IP address, enforces web access policies, filters content, and can cache web pages. A **Reverse Proxy** sits in front of servers and handles **incoming requests**. It hides backend servers, performs **load balancing**, **caching**, **SSL/TLS termination**, and provides additional security against attacks such as DDoS. From a SOC perspective, forward proxy logs help monitor user web activity, while reverse proxy logs help detect attacks targeting web servers.



Left Side – Forward Proxy (Protects Users)



What Happens?

1. A user wants to visit a website.
2. The request first goes to the **Forward Proxy**.
3. The proxy checks company policies.
4. If allowed, it forwards the request to the Internet.

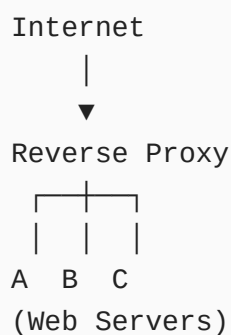
Who does it protect?

- ☒ **Clients (Users)**

Main Functions

- Hide the user's IP.
 - Filter websites.
 - Monitor browsing.
 - Cache web pages.
-

Right Side – Reverse Proxy (Protects Servers)



What Happens?

1. A request comes from the Internet.
2. It first reaches the **Reverse Proxy**.
3. The reverse proxy decides which backend server (A, B, or C) should handle it.
4. The selected server sends the response back through the reverse proxy.

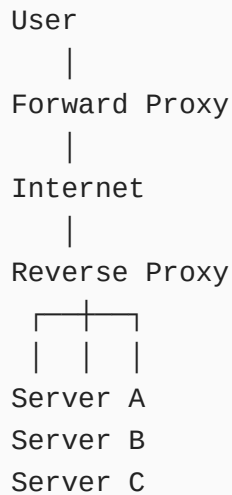
Who does it protect?

-  **Servers**

Main Functions

- Load balancing.
- Hide server IPs.
- Cache responses.
- SSL/TLS termination.
- DDoS protection.
- Web Application Firewall (WAF) integration.

Complete Flow



Explanation

- **Forward Proxy** represents the **client**.
- **Reverse Proxy** represents the **server**.
- The client never directly communicates with the backend servers.

SOC Perspective

Forward Proxy Logs

Monitor:

- Users visiting malicious websites.
- Malware downloads.
- Policy violations.
- Suspicious uploads (possible data exfiltration).

Example

```
User: Alice
URL: phishing-site.com
Action: Allowed
```

Reverse Proxy Logs

Monitor:

- SQL Injection attacks.
- Cross-Site Scripting (XSS).
- DDoS attacks.
- High request rates.
- Access to restricted URLs.

Example

```
Source IP: 185.221.x.x
Requests: 50,000/min
Target: Web Server
```

Possible Conclusion:

- DDoS attack or automated bot activity.

Easy Trick to Remember

Forward Proxy

👉 **Users → Proxy → Internet**

- Protects **Users**
- Handles **Outgoing Requests**

Reverse Proxy

👉 **Internet → Proxy → Servers**

- Protects **Servers**
- Handles **Incoming Requests**

A **Forward Proxy** sits between users and the Internet, handling **outbound requests**. It hides the client's IP address, filters web traffic, and enforces browsing policies. A **Reverse Proxy** sits in

front of backend servers and handles **incoming requests**. It hides server IP addresses, distributes traffic using **load balancing**, performs **caching** and **SSL/TLS termination**, and helps protect servers from attacks. In a SOC environment, **forward proxy logs** are used to monitor user web activity, while **reverse proxy logs** help detect attacks such as SQL injection, XSS, and DDoS targeting web servers.

SOC Logs (Proxy Logs)

A proxy server records user web activity, which helps SOC analysts investigate security incidents.

Information Found in Proxy Logs

- **URLs Accessed** – Websites or web pages visited by users.
 - **User Activity** – Which user accessed which website and at what time.
 - **Download/Upload Activity** – Files downloaded from or uploaded to the Internet.
-

SOC Indicators

These are common indicators of suspicious activity found in proxy logs.

1. Access to Malicious Websites

- User visits a known malicious or blacklisted domain.
- May indicate phishing, malware, or command-and-control (C2) communication.

2. Phishing Website Access

- User accesses a fake login page designed to steal credentials.

3. Suspicious File Downloads

- Downloading executable files (.exe, .dll, .zip, .js, .iso, etc.) from untrusted websites.
- May result in malware infection.

4. High Data Upload (Data Exfiltration)

- Large amounts of data uploaded to cloud storage or unknown websites.
- Could indicate an attacker stealing sensitive company data.

5. Access to Restricted Websites

- User bypasses company policies to access blocked or unauthorized websites.

6. Unusual Browsing Activity

- A user who normally visits business websites suddenly accesses hacking tools, dark web sites, or suspicious domains.

Example Proxy Log

```
Time: 10:15:30
User: john
Source IP: 192.168.1.25
URL: hxxps://malicious-site.com
Action: Allowed
Downloaded: invoice.pdf.exe
```

SOC Analysis

1. Validate

- Confirm the proxy log is genuine.
- Verify the user, timestamp, and URL.

2. Investigate

- Check whether `malicious-site.com` has a bad reputation.
- Verify whether `invoice.pdf.exe` was downloaded and executed.

3. Correlate

- Check:
 - DNS logs
 - Firewall logs
 - EDR/Antivirus logs

- SIEM alerts

4. Enrich

- Query threat intelligence for the domain and file hash.
- Determine whether the file is known malware.

5. Decide

- If the domain or file is malicious, classify it as a **True Positive**.

6. Escalate

- Isolate the affected endpoint.
- Block the domain in the proxy/firewall.
- Notify the Incident Response team.

Proxy logs record **URLs accessed, user activity, and download/upload events**. As a SOC analyst, I review these logs to identify suspicious indicators such as access to malicious or phishing websites, downloads of suspicious files, unusually large uploads that may indicate data exfiltration, and violations of company web access policies. I then correlate these events with firewall, DNS, endpoint, and SIEM logs to determine whether the activity is malicious or legitimate.

Flow after combining all together now

User -> Switch -> Router -> Firewall -> Proxy -> Internet

Device	What SOC Sees
Router	IP traffic
Switch	MAC Activity
Firewall	Allowed/Blocked traffic
IDS/IPS	Attack alerts
Proxy	User behaviors

Real SOC Scenario

Alert

User downloads a file from an unknown domain

Firewall : Allowed 

Proxy : Suspicious URL 

IDS : Malware Detected 

Conclusion

Possible Malware Infection Attempt

The firewall allowed the traffic because it matched its rules, but the **proxy identified the URL as suspicious**, and the **IDS detected malware** in the downloaded content. This indicates a likely attempt to infect the user's system.

SOC Investigation (Your 6-Step Workflow)

1. Validate

- Verify that the firewall, proxy, and IDS logs are genuine.
 - Confirm the user downloaded the file.
 - Check the timestamps to ensure the events are related.
-

2. Investigate

Gather details:

User: John
Source IP: 192.168.1.25
URL: unknown-download.com
Downloaded File: invoice.pdf.exe
IDS Alert: Trojan Detected

Questions:

- What file was downloaded?
- Did the user execute it?
- Which endpoint is affected?

3. Correlate

Compare logs from multiple sources:

Security Tool	What to Check
Firewall	Was the connection allowed?
Proxy	Which URL was accessed?
IDS/IPS	Was malware detected?
EDR/Antivirus	Was the file executed?
DNS Logs	Was the domain resolved?
SIEM	Are there related alerts?

Correlating multiple log sources helps confirm whether this is a real attack.

4. Enrich

Use threat intelligence to check:

- Domain reputation.
- Source IP reputation.
- File hash (SHA256).
- Malware family.

5. Decide

Based on the evidence:

- Unknown domain.
- Suspicious URL.
- IDS detected malware.

Decision: True Positive – Malware Infection Attempt

6. Escalate

- Isolate the endpoint.
 - Block the malicious domain/IP.
 - Quarantine or remove the file.
 - Notify the Incident Response team.
 - Perform a full malware scan.
-

Analyst Thinking

When a SIEM alert arrives, first ask:

Where did this happen?

Area	Device / Log Source	What It Tells You
Internal Network	Switch (MAC Address)	Which internal device is involved?
Network	Router (IP Address)	Where is the traffic coming from or going?
Security Perimeter	Firewall / IDS / IPS	Was the traffic allowed, blocked, or identified as malicious?
User Activity	Proxy	Which website did the user access? What did they download or upload?

Easy Way to Think Like a SOC Analyst

Whenever you receive an alert, ask yourself these questions:

1. **What happened?** (Malware, brute force, phishing, etc.)
2. **Where did it happen?** (Switch, Router, Firewall, IDS, Proxy, Endpoint)
3. **Who is involved?** (User, IP address, Hostname)
4. **When did it happen?** (Timestamp)
5. **Is it malicious or legitimate?** (Correlate logs and enrich with threat intelligence)

6. **What should I do next?** (Contain, block, escalate, or close as a false positive)

In this scenario, the **firewall allowed** the download because it matched the configured rules, the **proxy flagged the URL as suspicious**, and the **IDS detected malware** in the traffic. As a SOC analyst, I would validate the alerts, investigate the downloaded file and affected user, correlate firewall, proxy, IDS, and endpoint logs, enrich the indicators with threat intelligence, and determine whether it is a true positive. Since multiple security controls indicate malicious activity, I would classify it as a **malware infection attempt**, isolate the affected endpoint, block the malicious domain, and escalate the incident for further response.